

Thiscovery Forms review, version 3

A full review of 1.30.0: the 1.28.4–1.28.7 fix releases, 1.29.0 (loops, quotas, eConsent, randomisation) and 1.30.0 (the formula engine). It checks all 126 earlier findings and looks for defects introduced since 1.28.3.

Code reviewed thiscovery-forms-5 (v1.30.0): about 73,000 lines, with a 27,700-line diff since 1.28.3

Reviewed 30 Sept 2026

Method Code reading plus standalone PHP/Node test harnesses for the formula engine and randomisation



The tiles cover the 126 earlier findings: 104 from version 1 and NEW-1 to NEW-22 from version 2. The release also introduces **57 new defects**, V3-1 to V3-57: 8 Critical, 28 High, 17 Medium and 4 Low. Most Low and Medium entries group several related issues.

Verdict: impressive breadth, but not ready for production or real study data

This is a large amount of well-structured work. Almost every version 2 defect is fixed (15 of 22 fully), and so are the originally Critical data-loss problems. The server-side formula engine is safe from code execution and correct on decimal arithmetic. Loops, quotas, eConsent and randomisation all exist, with sensible data models, rollback guards and user docs.

But the release breaks the three things a research survey platform can't compromise on:

- **The browser and server agree on the route.** They no longer do. Formula go-to and skip-page rules never fire in the browser (V3-1). The browser evaluator lacks about 15 operators, `concat` crashes it, and `today()` is hard-coded to 30 Sept 2026 (V3-9, V3-10, V3-14). So the silent answer loss LOG-1 described is back, in more places.
- **Anonymity holds.** It doesn't. Completion emails log member and answer together (V3-2), "unlinked" consent records can be joined to answers (V3-26), and the public dashboard shows roster names (V3-8).
- **Research methods are correct.** They aren't. The shuffle reaches only a fraction of the possible orders and correlates them across questions (V3-5). Block randomisation isn't balanced under concurrency (V3-6). Editing a response double-counts quotas (V3-7). Choice code "0" is treated as unanswered, which breaks PHQ-9/GAD-7 scoring (V3-11).

The common cause is **testing that doesn't match the risk**. The 500 formula vectors are mostly trivial, the routing vectors were deleted instead of converted, and nothing tests PHP/JS parity for each operator, randomisation statistics, quota concurrency, or PII exposure on public pages.

Recommendation: hold 1.30.0. Ship a 1.30.1 stabilisation release that fixes the 8 Critical and the P1 High items in section 6, and adds the test gates listed there. Don't use randomisation, quotas or eConsent in a real study until they have passed those gates.

1. Feature scorecard

AREA	STATUS	ASSESSMENT	BLOCKING DEFECTS
Safety fixes (1.28.4–1.28.7)	MOSTLY DONE	Covers the version 2 blockers, hotfix B, LOG-4, the between operator, MaxDiff, editions, integrity routing, the Delphi consensus bands, export logging and accessibility. Good, careful work.	V3-32, V3-36, V3-51
Formula engine (1.30.0)	NOT READY	The PHP side is safe (no eval, parser limits hold) and its decimal arithmetic matches the agreed rules. But the server doesn't fully own calculated values, the browser evaluator is incomplete and diverges from PHP, several advertised references are always empty, and there's no size limit on numbers.	V3-1, V3-3, V3-4, V3-9 to V3-14
Loops and rosters (1.29.0)	NOT READY	The storage change and the security of roster keys are good. Nested loops, numeric codes, file questions, piping and per-repeat visibility are broken, rosters can't be exported, and the dashboard exposes names.	V3-8, V3-15 to V3-20

AREA	STATUS	ASSESSMENT	BLOCKING DEFECTS
Quotas (1.29.0)	NOT READY	Counters are locked in id order inside the submit transaction, which is right. Edits double-count, cells ignore calculated and URL values, go-to traps the respondent, expiry and reconcile race, and redirects aren't validated.	V3-7, V3-21, V3-23, V3-24, V3-31
Randomisation (1.29.0)	NOT USABLE FOR RESEARCH	The design is good (server-side seed, stored orders, no reshuffling in the browser). But the random number generation is statistically broken, block allocation races, guests see an order other than the one recorded, and over-quota respondents' arms are deleted.	V3-5, V3-6, V3-22, V3-25
eConsent (1.29.0)	NOT READY	Versions are frozen, records are append-only in practice, withdrawal tokens are good, and permissions are separate. But anonymous records are linkable, the hash doesn't match what was shown, signature rules can be bypassed, re-consent emails are never sent, and the drawn signature doesn't work.	V3-26 to V3-29
Webhooks	NOT BUILT	Deferred in the changelog. <code>quota.full</code> and the consent events aren't sent.	—
Answer audit and erasure (1.30.0)	PARTIAL	Tables and flows exist, but the reason is never collected, the actor is missing on anonymous forms, and erasure leaves a lot behind.	V3-30, V3-44

2. New defects introduced since 1.28.3

Findings tagged **Verified** were re-checked directly against the source for this report. The formula, randomisation and loop findings marked "Run" were reproduced with standalone harnesses. Other findings come from careful code reading; "Plausible" marks those that need a runtime check.

Critical (8)

CRITICAL In the browser, formula go-to and skip-page rules never fire, so LOG-1 is back

V3-1 · Routing **Verified**

resources/js/humhub.thiscoveryForms.js:4068, :4074, :4142 ·
models/FormField.php:2187-2193

Formula logic is saved as `{v, action, when, text, goto}` with no `rules` key. But the browser's `pageShouldSkip` and `resolveNavigation` still only act when `logic.rules.length` is non-zero, so every formula go-to, go-to-end and skip-page rule is ignored in the browser. The server (`LogicEngine::pageNavigation`) does apply them.

Scenario: Q1 has "go to page 5 if [q1] = 2". The browser shows pages 2–4. The server's route is 1 → 5, so the answers typed on pages 2–4 are silently dropped. The reverse case produces "required" errors for questions the respondent never saw.

Fix: test `logic.when` (as `isLogicVisible` already does). Bring back the shared routing test vectors, which were deleted rather than converted.

CRITICAL

Completion and action emails link fully anonymous answers to the person again (GOV-2 regressed)

V3-2 · Anonymity **Verified**

services/PanelService.php:556-571 · services/EmailTemplateService.php:257-266 ·
services/FormActionService.php:358

On fully anonymous forms, `handleCompletion` now sends the completion email. `sendTemplate` logs `member_id`, `answer_id` and the recipient address in `custom_form_email_send`, which ties a named panel member directly to the "anonymous" answer. Action emails log the same pair. The member's weight is also copied onto the answer, so a unique raking weight identifies the person (Plausible).

Fix: on fully anonymous forms, write email-send rows without `answer_id` (or without the member), don't copy the weight, and add a test that no table joins member to answer.

CRITICAL A calculated value posted by the browser leaks into other calculations

V3-3 · Formula

services/formula/FormulaRuntime.php:36-60 · models/SubmitForm.php:199

Calculated fields pass `collectsAnswer()`, so their posted value goes into `$values`. `fill()` builds the context before recomputing, and there's no dependency ordering. So a calculation that reads a *later* calculated field reads the attacker's number.

Run: $x = 5$, $a = [b] * 2$, $b = [x] + 1$, with b posted as 999999. The stored a is **1999998**; it should be 12. This breaks decision 10 ("posted calculated values are ignored").

Fix: clear every calculated value before building the context, evaluate in dependency order, and reject cycles.

CRITICAL Very large numbers let a participant use up server CPU V3-4 · Formula

services/formula/Decimal.php (no size cap) · models/SubmitForm.php:387, :510 · controllers/FormulaController.php

Decimal arithmetic has no digit limit, and multiplication and division are quadratic. A number question accepts any length (only `is_numeric` is checked), and calculations run before validation. An 8,000-digit answer to a form that uses `[x]/3` or `mean()` takes about 10 seconds per request. On the login-only preview endpoint, `(9999999999^20)^20` takes 22 seconds using 5 evaluation steps, and a third level of nesting is unbounded.

Fix: cap the digits of every parsed and computed value (for example 30 whole digits, giving empty on overflow). Validate number length before calculating. Restrict the preview endpoint to form managers and rate-limit it.

CRITICAL

The shuffle is biased and can only reach a fraction of possible orders, and orders are correlated across questions

V3-5 · Randomisation Verified

services/RandomisationEngine.php:14-24, :150-153 · models/FormField.php:1338-1343

The shuffle uses the low bits of a power-of-two LCG (`seed % (i+1)`), and each scope's seed is `crc32(seed:scope)`, which is linear. Measured over 300,000 seeds:

- 4 items reach only 12 of 24 orders; 8 items reach 2,520 of 40,320.
- Item 4 is shown first 8.4% of the time instead of 25%.
- Two 2-option questions always get the *same* order.
- Block randomisation with 2 arms and block size 4 gives arm A the first slot 58% of the time.

Any analysis of order effects or allocation is compromised.

Fix: run Fisher–Yates driven by HMAC-SHA256 (keyed by the response seed and the scope), with rejection sampling to avoid modulo bias. Add position-uniformity and cross-scope independence tests.

CRITICAL

Block allocation reads the counter before locking it, so concurrent starts break balance

V3-6 · Randomisation Verified

services/RandomisationService.php:835-866, :726-743

`$row` comes from a plain SELECT. The later `SELECT ... FOR UPDATE` result is thrown away, so `$block` and `$index` come from the stale read. Two parallel starts can get the same slot, one slot is skipped, and the block is no longer balanced. `nextRotateOffset` has the same bug. On the first allocation of a new stratum, two concurrent inserts collide on the primary key, and the whole submit rolls back ("Could not save your submission").

Fix: lock first and use the locked row. Create the row with `INSERT ... ON DUPLICATE KEY UPDATE`, then lock it.

CRITICAL**Editing a completed response counts it towards the quota again, or turns it into over-quota**

V3-7 · Quotas

services/QuotaService.php:395, :931-938 · models/SubmitForm.php:956-964, :1337-1340

Quotas skip already-counted answers only when `outcome` isn't empty. But `complete` is only written when randomisation is on, so on a form with quotas and no randomisation, completed answers have `outcome=' '`. A manager edit runs `apply()` again: `accept()` adds 1 every time, and if the quota is now full the edited response is marked `over_quota`, which removes a genuine complete.

Fix: skip answers that were already complete before this save, and make `accept` increment only when its accept row is newly inserted.

CRITICAL The public dashboard shows free-text loop answers and roster namesV3-8 · Loops Verified

services/DashboardService.php:847-924, :183 · views/form/dashboard.php:153-195

`loopBreakdown` counts every loop question whatever its type, shows each value verbatim (up to 80 characters), and replaces the instance label with the typed roster name. It's part of `getFormDashboard`, which also feeds the *public* dashboard. PII flags and identity mode are ignored.

Scenario: a household roster with a "name" question. Anyone holding the share link sees the names and free-text answers.

Fix: only aggregate structured types, never label rows with names, skip PII fields, and hide the loop panel on public dashboards.

High (28)

HIGH

today() isn't frozen per response, uses the wrong time zone, and is hard-coded to 2026-09-30 in the browser

V3-9 · Formula Verified

resources/js/thiscoveryForms.formula.rules.js:75 · services/LogicEngine.php:252 · services/formula/Context.php:79 · FormulaRuntime.php:13-25 · SubmitForm.php:762

The browser's `today()` falls back to the literal `'2026-09-30'`, because nothing ever sets `__today`. Server-side rules use `gmdate` (UTC now). Calculations use "now" in the form's zone. `formula_today` is written but never read. So agreed decision 4 (freeze the date at response start, in the form's time zone) isn't implemented. Rules such as "eligible if `date_diff([dob], today(), "years") >= 18`" drift apart between browser and server every day, and change between saving and resuming.

Fix: read `formula_today` everywhere, and send it to the browser in the page config.

HIGH **The browser evaluator is incomplete and doesn't match PHP** V3-10 · Formula

resources/js/thiscoveryForms.formula.rules.js:64, :97-273, :241

About 40 of 105 adversarial expressions gave different results in PHP and the browser.

- **Returns empty in JS:** `mod`, `in / not_in`, `fn:`, `count_eq`, `count_selected`, `sqrt`, `coalesce`, `ifempty`, `lower / upper / length`, `year / month`, `selected`, `code_of`.
- **Always false in JS:** date ordering.
- **between with reversed bounds** differs.
- **concat throws** ("text is not a function", because `var text` shadows the helper). The exception stops every show/hide update on the page. The EQ-5D starter formula uses `concat`.
- **Choice codes are typed differently:** JS looks up the field type by variable name against numeric ids, so it treats codes as numbers. PHP treats them as text, so `[r] > 1` is true in JS and false in PHP. On the server, PHQ-style `[phq1] >= 2` is always false.

The 500 shared test vectors are about 480 trivial operator × string cases, and cover none of this.

HIGH Choice code "0" counts as unanswered V3-11 · Formula **Verified**

services/formula/Evaluator.php:615-628 · services/formula/Value.php:47-57

`answered()` and `Value::truth()` treat the text "0" as empty. So a radio answered "0" (PHQ-9/GAD-7 "Not at all", or the 0 on a 0–10 scale) gives `is_answered` = false and `count_answered` = 0, and `if([r], ...)` takes the false branch. Pro-rated scores then undercount. The only legitimate "0 means unchecked" case is already handled in `Context::leaf`.

HIGH Arithmetic and logic functions give wrong results V3-12 · Formula **Verified**

services/formula/Evaluator.php:50-51, :168-180 (mod) · sqrt

- `%` rounds the quotient half away from zero instead of flooring it, so `8 % 3` = -1, `7 % 2` = -1 and `7.5 % 2` = -0.5.
- `sqrt` runs 20 Newton steps from a guess of 1, so `sqrt(10^12)` = 1,279,996.5 and `sqrt(0)` = 0.00000095.
- `and` / `or` with more than two arguments drop some of them: `and(true,true,false)` gives true, and `or(false,false,true)` gives false. These are the trees `RuleBuilder` produces.

HIGH

Variables advertised in the docs are always empty on the server, and URL parameters aren't kept

V3-13 · Formula **Verified**

services/formula/Context.php:76-108, :133-156 · models/SubmitForm.php:386, :828 · models/CustomForm.php:845

`[var:...]`, `[panel:...]` and `[meta:...]` are filled only from key prefixes that `SubmitForm` never adds. Grid row references (`[q.row]`) are always empty, and `fn:name` is always empty because `Context->named` is never set outside tests. URL parameters are re-read from the *current* request, and never stored on the response. They're lost on resume, save-progress, manager edits, and HTTP→HTTPS redirects (which `Url.php` already warns drop query strings). Rules and calculations that depend on them change after the first request, and answers are dropped.

Fix: capture declared variables and URL parameters once at response start into `variables_json`, and build every context from that.

HIGH In the browser, calculated values are lost before visibility runs V3-14 · Formula

resources/js/humhub.thiscoveryForms.js:4639 onward

Calculated values are computed once, then `values = readAnswers()` inside the visibility loop overwrites them with `''`. Calculated fields whose display is "hidden" are never computed in JS at all. So `show if [bmi] >= 30` is hidden in the browser but visible and required on the server.

HIGH Numeric repeat codes break loop answers and aggregates V3-15 · Loops

services/formula/Context.php:146-156 · models/SubmitForm.php:92-99

PHP converts keys like `"1"` to integers, and `isInstanceMap` rejects integer keys. So with option codes 1–5, which are typical, `[q[*]]`, `[q[code]]` and every any/all/count/sum aggregate return empty. `isInstancePost` uses `!array_is_list`, so repeat codes starting at "0" (a 0–4 Likert scale, or only option 0 selected) are read as a plain choice list, and the repeat answers are destroyed.

Fix: detect instances from the known instance paths, not from the key shape, or prefix instance keys internally.

HIGH Nested loops render the wrong questions V3-16 · Loops

services/LoopService.php:806-844, :660

`splitPage` keeps an inner group's start row but drops its end row. With `Outer{Q1, Inner{Q2}, Q3}`, Q3 is rendered once per inner repeat, but saved under the outer key. Its answers are dropped, and a required Q3 can never be satisfied. With `Outer{Plain{P1}, Inner{Q2}}`, Inner is flattened and Q2 is lost. The loop test only covers adjacent group ends.

HIGH File and HTML questions inside a loop never save V3-17 · Loops

models/SubmitForm.php:115, :174, :234, :869-872

A file answer is checked with `is_string()`, so an array of repeats becomes `''`.

`acceptFileGuid` also ignores `instance_key`. For HTML questions, `array_values()` strips the instance keys. Map questions are Plausibly affected too. Either parse every type per instance, or block these types inside loops when authoring.

HIGH**In loops, piping, browser logic and server visibility all work on one instance instead of each repeat**

V3-18 · Loops

`resources/js/humhub.thiscoveryForms.js:3682-3874 · formula.rules.js:346-360 · models/SubmitForm.php:403, :866-904`

`applyPiping` rewrites every piped label in the browser without knowing about `loop.*`. So `{{loop.label}}` shows as the literal token, `{{answer:x}}` shows the last repeat, and `readAnswers` keys values by field only, so every repeat overwrites the last. The browser's `ruleTruth` only supports `any`. On the server, `validate` checks visibility once with the whole instance map, and the loop save ignores visibility entirely. So "If yes, when?" inside a repeat is judged across all repeats: respondents get stuck, or hidden answers are stored.

HIGH Loop data is missing from exports V3-19 · Loops`services/LoopService.php:172, :485, :503-511 · ExportService.php:212, :353`

- For "selected options" loops with a maximum, save keeps the first N *selected* options, but export columns use the first N *defined* ones. Selecting options 7 and 8 stores the data, but it has no column.
- Rosters have no wide columns at all, and the long export has no controller or UI, so roster data can't be exported.
- If the long export were wired up as written, it would skip column rules, PII scrubbing, CSV neutralisation and export logging.

HIGH Loop column checks cause hundreds of thousands of queries V3-20 · Loops`services/LoopService.php:35, :899 · models/FormAnswer.php:350-378`

`columnReady` / `rosterColumnReady` call `getTableSchema(..., true)`, which reloads the schema from the database on every call. They run for every field of every answer during export, validation, save and `getValuesMap` (which also bypasses eager loading). An export of 5,000 answers × 100 fields makes about 500,000 schema queries. The integrity similarity check does the same across 250 other answers on every submit.

HIGH Quota rules are checked before calculated values and URL parameters exist

V3-21 · Quotas

models/SubmitForm.php:804 vs :828-829 · services/QuotaService.php:192

`QuotaService::apply` runs before `applyDeclaredUrlParams` and `FormulaRuntime::fill`. Quota cells that use `var: / url: /`calculated values (which authoring accepts) are never counted. Reconcile uses the stored values and does count them, so the live counter and the reconcile count always disagree. Stratified allocation has the same ordering problem. Cells are also matched against raw posted values, including hidden answers (Plausible).

HIGH Guests see a different order from the one recorded V3-22 · Randomisation

views/form/view.php:50-61 · FormField.php:1321-1333, :1388-1412 · JS autosave 2662-2700

A new respondent has no answer row yet, so the page renders with authored page order and a session-seeded option shuffle. The first autosave then creates the answer and draws and stores a *different* order, but doesn't re-render. So the export reports orders the respondent never saw, and page-block randomisation never happens in a single sitting. LOG-6 has the same problem.

Fix: create the answer and seed on the first page view, before rendering.

HIGH A quota's "go to page" action traps the respondent V3-23 · Quotas

models/SubmitForm.php:951-955

The goto branch leaves the response open with `outcome=''`. On final submit the same full quota is checked again and sends them back, so they can never finish unless the goto page changes their cell. Reconcile also counts these respondents against the full quota. Record the diversion, and exclude it from both the check and the recount.

HIGH Races in reservation expiry and reconcile can overfill a quota V3-24 · Quotas

services/QuotaService.php:612-633, :652-667

- **Expiry** reads the expired rows before locking, then subtracts `count($ids)` instead of the number of rows it actually deleted. Rows a concurrent submit already converted are released twice, freeing phantom places.
- **Reconcile** recounts without a lock, then writes an absolute total, overwriting any accepts committed in between. `quota_accept / released` are never rebuilt.

HIGH

Arm assignments are deleted, and quota-driven arm choice is neither random nor honestly logged (methodology)

V3-25 · Randomisation

services/QuotaService.php:360, :381, :1136-1138 · RandomisationService.php:621

`halt()` deletes an over-quota respondent's arm assignment. That's a post-randomisation exclusion with no audit, and it leaves a used block slot with no record. With `quota_assign_arm` on, the arm is chosen deterministically by fewest accepted, from unlocked counters, while the log still records the configured method.

HIGH

An unlinked consent record on a fully anonymous form can still be linked to the answer

V3-26 · eConsent

services/ConsentService.php:117-127, :868, :929-950, :1039-1063

The "unlinked" record still stores the typed signature name and the witness name, `signed_at` to the second, a sequential id, and IP/UA hashes salted with a value kept in the form's settings (2^{32} IPv4 addresses can be brute-forced). It's written in the same transaction and second as the answer. The consent list and the CSV export give a manager everything needed to join a name to an answer. The signature image is a HumHub `File`, whose `created_by` is Plausibly the user.

Fix: for unlinked records, allow only checkbox attestation; store the date only; store no names, hashes or files; use random ids or a separate table.

HIGH The consent hash isn't a hash of what the participant saw V3-27 · eConsent

views/form/_field_fill.php:108 · _consent_sheet.php:11, :17 ·
ConsentService.php:596, :782-821, :936

The page shows the base-language text, but the record hashes the *translated* text for `response_language`. Translations can still be edited after publishing, both in the UI and by import. The published hash also leaves out the title and attachments. Hash exactly the rendered text, and lock or version translations when the document is published.

HIGH Signature method, witness and must-read rules can be bypassed from the browser

V3-28 · eConsent

`services/ConsentService.php:861-865, :901-911`

The posted `signature_method` is trusted. Posting `checkbox&attestation=1` on a "typed" or "drawn" field passes. Witness details are never required, and `must_read` / `scrolled_to_end` come from the browser and are never checked on the server. Separately, the drawn-signature canvas has no script behind it, and "read to end" is only recorded when keyboard focus reaches the end marker, so mouse and touch users are recorded as not having read it.

HIGH Test-only guards silently stop real emails V3-29 · Release hygiene **Verified**

`services/ConsentService.php:1104 · services/QuotaService.php:48, :968`

Re-consent emails and quota-full notifications are skipped unless the address ends in `@example.test`. Leftovers from the test harness mean these features never email real participants or managers. Remove the guards, and rely on the mail transport for test isolation.

HIGH

The identity repair log keeps the links it was meant to remove, and erasure is incomplete

V3-30 · Governance

`services/IdentityRepair.php:99-107, :159-172 · services/ErasureService.php:18-75 · Events.php:142`

The repair log stores the old `created_by`, `panel_member_id`, `resume_email` and token hash for each answer, with no expiry. It also leaves email-send rows, consent links and integrity hashes in place. User erasure finds answers only by `created_by`, so token or invite answers are skipped. It leaves consent records (name, signature file), withdrawals, email logs, integrity hashes, repair-log rows and `answer_audit.old_value` in place. It writes file values into the audit log, and runs without a transaction.

HIGH A quota redirect can be a `javascript:` URL or point at any host V3-31 · Security

Verified

`services/QuotaService.php:80, :1163-1172 · controllers/QuotaController.php:74-81 · views/form/thankyou.php:73`

`saveQuota` stores `action_url` without checking it; only the publish-time check looks at it, and that only raises a flash message. `redirectUrl()` doesn't check it at runtime. The allowlist is per form and editable by any form manager. `javascript:...` ends up in an `href` on the thank-you page, and `Html::encode` doesn't block that scheme, so it runs in the participant's session when they click Continue.

Fix: require https and an allowlisted host when saving and at runtime, and make the allowlist admin-only at module level.

HIGH A one-time invitation is used up before the submit checks pass V3-32 · Integrity

`services/integrity/IntegrityService.php:192 vs :198-214 · controllers/FormController.php:272-281`

The token is consumed before the CAPTCHA, rate limit and validation run. An invitee who fails the CAPTCHA once, or leaves a required question blank, then retries and is told they need a unique invitation link. Consume the token only after a successful save.

HIGH Removed questions count as shown in integrity checks V3-33 · Integrity

`services/integrity/IntegrityService.php:1017`

`shownFieldIds` uses `getAllFields()`, which includes removed questions. If an attention check is removed after launch, every later respondent "fails" it, and `shown_question_count` (the basis of the speeding check) is inflated.

HIGH Every poll-embed vote is rejected in suspicious or always CAPTCHA mode

V3-34 · Integrity

`controllers/StudioTrait.php:605`

The embed has no CAPTCHA widget and never sets the integrity session key, so the gate rejects every vote whenever integrity is on in "suspicious" mode, or in "always" mode.

HIGH Screened-out and over-quota responses are included in analyses V3-35 · Analytics

`services/DashboardService.php:52-75, :197, :221, :517 · SubmitForm.php:963`

These responses are stored with status complete. Charts, MaxDiff, Delphi consensus, and the per-wave and per-round "completed" counts filter on status only. Only the overview and the arm counts filter on outcome. Filter on outcome in `scopeIncludedInAnalysis`.

HIGH

Removing an unanswered question from the draft blocks every submit on the published edition

V3-36 · Versioning

models/CustomForm.php:2694-2702 · FormSnapshotService.php:285 · SubmitForm.php:844-854

The NEW-11 fix hard-deletes removed questions that have no answers. The published edition still shows the question, and its answer insert then fails the RESTRICT foreign key. The whole submission and every autosave roll back for anyone who answers it. Alternatively the variable/label fallback binds it to a different question. Never hard-delete a question that appears in any edition snapshot.

Medium (17)

MEDIUM

A studio save that fails validation is still written V3-37 · Studio

models/CustomForm.php:2605-2630, :2729-2760

`saveFieldsFromPost` writes and deletes fields, and only *then* runs the checks for backward go-tos, loops, quotas, consent, policy and legacy rules. It then returns false, so the invalid design is stored anyway, the user sees "some fields could not be stored", and `recordSave` is skipped. Studio save, clone, import and restore still have no transaction (DAT-3 is only partly fixed). Validate first, then write inside a transaction.

MEDIUM

Formula edge cases: in/not_in can't be parsed, list arguments cause 500s, and there's no dependency graph

V3-38 · Formula

services/formula/Parser.php:321 · LogicEngine::evaluateRule · FormulaRuntime.php:37-50

- The lexer reads every `[` as a reference, so `[a]` in `[1, 2]` fails to parse.
- A list on the right-hand side, or passed to a text function, throws "Array to string conversion". That's caught in calculations, but not in `evaluateRule`, so it causes a 500 on submit.
- There's no dependency graph or cycle detection for calculated fields.
- All calculated fields share one 10,000-step budget, and running out silently stores null.
- Logic-hidden answers feed calculations (calculations use raw values).
- Plausible: `{{answer:...}}` is substituted into action formulas *before* parsing, which allows formula injection.

MEDIUM Visibility checks may cost roughly $O(n^3)$ per request (Plausible)

V3-39 · Performance

services/LogicEngine.php:290-365 · Context.php:76-108

`isFieldVisible` calls `valuesIgnoringHidden` (up to n passes $\times$ n fields), which rebuilds the context and decodes options for every field on every rule evaluation. That repeats for each field in `validate` and `save`. Compute the effective values once per request, and benchmark on the 300-question form.

MEDIUM `run-actions` limits and side effects V3-40 · Security

services/FormActionService.php:190-199 · controllers/FillResumeTrait.php:762-769

- The limit is 60 per 10 minutes per IP per form, and it fires after any change. Respondents behind a hospital NAT hit it, and `set_variable` then silently stops.
- Every cookieless call creates a draft answer, even when there are no actions.
- It's still an email relay within that limit, and rotating IPv6 addresses gets round the per-IP count (SEC-5).
- The cache get/set isn't atomic.

MEDIUM Negative numbers are exported as text V3-41 · Export

helpers/CsvCell.php:42

The formula-injection guard prefixes any cell starting with `-`, so `-3` is exported as `'-3'`, which breaks numeric columns in R, Stata and SPSS. Don't prefix values that parse as numbers. The codebook and allocation CSVs aren't neutralised at all.

MEDIUM Scoring and instrument problems V3-42 · Scoring

FormField.php:1926-1929 · Evaluator.php:666 · FormulaLibrary.php:42 ·
MaxDiffDesigner.php:26-54 · Eq5dService.php:86

- **MaxDiff sets are rebuilt** on the first studio save after an upgrade, so existing answers are scored against new sets.
- `score_of` falls back to the raw code, so a "prefer not to say" option coded 9 adds 9.
- `eq5d_profile` drops a missing dimension and returns a 4-digit profile.
- **MaxDiff with 10 items, sets of 4, 5 sets** never shows items 9 and 10 (SCO-1 regressed for this case).
- **EQ-5D fallback:** when only 4 dimensions are tagged, it still scores the first 5 untagged radio questions.

MEDIUM Consent data problems V3-43 · eConsent

_field_fill.php:122-127 · _consent_sheet.php:24 · FormPanelMember.php:161 · ConsentService.php:418-426, :541-562

- **Unticked required checkbox:** it posts `no`, so an accidental miss is recorded as a refusal (not consented), not as a missing answer.
- **Panel consent:** `consent_at` is no longer set on any form without eConsent, so the panel's consent column is empty.
- **Withdrawal:** it only reaches panel members, and clearing the token isn't atomic.
- **Certificate:** it shows codes, with no names or item labels, and there's no PDF.
- **Signature images:** there's no size or decode check.
- **Accessibility:** the consent checkbox has no accessible name, and the Yes/No radios aren't grouped.

MEDIUM Gaps in the answer audit trail V3-44 · Governance

models/SubmitForm.php:1343-1354 · AnswerAudit.php:28-38

No UI posts `change_reason`, so every entry says "edit". The actor is null whenever `created_by` is null, so no manager edit on an anonymous form is attributed, although the manager's identity is safe to record. Adding a value to a blank answer isn't audited. There's no viewer for the audit trail.

MEDIUM Loop answers can be collapsed, left stale or skip validation V3-45 · Loops

views/form/project.php:22-26 · FormAnswer.php:184, :304 · FormsDataProvider.php:226, :248 · SubmitForm.php:414-470 · QuotaService.php:517, :1212 · view.php:202-208

- **Collapsed instances:** the project view, `getFieldValue`, the dashboard-module packer and the record title still collapse repeats into one.
- **Unticking:** unticking every box in a repeat doesn't clear it, and one "Other, please specify" text is applied to every repeat.
- **Validation:** one blank repeat skips type validation on all the others.
- **Page indexes:** quota checks use unexpanded page indexes, and resume returns to the wrong loop when two loops share codes.
- **Dashboard:** it counts hidden repeats and ignores filters.
- **Answer detail:** it shows raw instance keys.

MEDIUM Loop settings are lost on import and translation V3-46 · Loops

QuestionImportExportService.php (no loop_* columns) ·

TranslationImportExportService.php:385, :533-569 · LoopService.php:714, :1140

Question import/export drops the loop settings. Translation export emits loop label units that import silently skips. The "X of Y" / "Row" headings are built by string concatenation, so they can't be translated. Clone copies `field_key` unchanged (Plausible: it points at the source form).

MEDIUM Smaller quota correctness issues V3-47 · Quotas

FillResumeTrait.php:540 · QuotaService.php:83, :93-103 · ExportService.php:337-341

· IntegrityService.php:409-420

- **Page-exit checks over AJAX** only return a note: an "end" action leaves the respondent filling a response that's already closed, and "goto" never moves them.
- **Mid-fieldwork changes:** changing a quota's rules isn't audited, and saving without a status reopens a closed quota.
- **Allocation CSV** throws "Undefined array key", so it's broken.
- **Integrity reinstatement** never returns the quota place.

MEDIUM Smaller randomisation method issues V3-48 · Randomisation

RandomisationEngine.php:94-103 · RandomisationService.php:819-832

- **Block size:** it's not validated against the arm weights. With 3 arms and size 4, blocks are A,A,B,C; with weights 2:1 and size 4, the ratio comes out 3:1.
- **Least-filled:** it's unlocked, deterministic apart from ties, and counts abandoned assignments. Allocation concealment is weak.
- **Missing features:** there's no per-response allocation log with timestamps, the admin override isn't wired to any controller, and preview advances the live rotation counter.

MEDIUM Accessibility gaps in the new and fixed widgets V3-49 · Accessibility

_field_fill.php:199, :374-381, :425-432, :839-841 · JS 2916-2980, 4282-4311

- **Best/Worst and MaxDiff** radios still have no accessible name, and their headers have no `scope`.
- **Rating, hotspot, drilldown, ranking and grid** aren't grouped, and `label for` still points at nothing.
- **Loop errors** share one error id across repeats.
- **Error summary** has no links.
- **Grid copies:** the desktop and mobile copies aren't mirrored, so zooming to 200% submits the stale copy.
- **Page focus:** the page that receives focus has no accessible name.

MEDIUM Security fixes with gaps V3-50 · Security

FormActionService.php:69, :327 · StudioTrait.php:499 · CustomForm.php:559-565 · UploadQuota.php · SubmitForm.php:203-204 · UploadGrant.php:61-87

- The send-email action's `template_id` isn't checked against the container.
- `library-insert` has no create-permission check.
- The folder ACL can be bypassed through `folder_id` on a studio save.
- The upload quota lives in the session, and trusts the posted `field_id`.
- Posting `other_text` overwrites a frozen "Other" answer.
- `grantLegacy` grants any unattached GUID already in a draft, plus the user's last 50 unattached HumHub files from any module.
- Respondents can still see the full answer list and the integrity dashboard (SEC-11).

MEDIUM Integrity scoring regressions V3-51 · Integrity

IntegrityService.php:832-849, :970-1008, :1487-1510, :1561-1567

- **Rate limit:** it's now keyed by /24 network, so the 9th submitter on a hospital NAT within 10 minutes is blocked (SEC-8/INT-8 regressed).
- **Speeding threshold:** a legacy value of 60 is read as 60 seconds per question.
- **Similarity:** it isn't chance-adjusted, so five "Neutral" answers give 100%.
- **Loop attention checks** pass if any repeat matches.

MEDIUM **Import, clone and edition reference gaps** V3-52 · Data

QuestionImportExportService.php:355-436 · FieldRefRewriter.php:54-71 ·
SubmitForm.php:658-678 · Context.php:133-137

- **Import** rewrites references only in `logic_formula`, not in calculated formulas, branch text or row/all references.
- **Clone** doesn't rewrite piped labels.
- **Mid-fill publishing:** a new response is validated against the *current* edition but stamped with the old one.
- **Renaming a variable** leaves every `[old]` formula dangling, with no check.
- **Variable names:** a variable named `id5` collides with field 5.

MEDIUM **Migration issues** V3-53 · Migrations

m260929_210000 · m261001_100000 · m261001_150000

- **eConsent backfill:** it's $O(\text{members} \times \text{forms})$, and there are no indexes on `consent_record.panel_member_id` or `consent_withdrawal.panel_member_id`, which reminds query.
- **Unique index:** the old one is dropped before the new one is created, leaving a window with no uniqueness.
- **Condition columns:** dropping them can't be undone. That's acceptable pre-production, but it should be documented.

Low (4)

LOW Smaller formula issues V3-54 · Formula

services/formula/★

- Dates aren't validated: `date("2024-2-3")` compares as text, and 2024-02-30 is accepted.
- `add_days` with huge values gives NaN in JS.
- `concat` truncates by bytes and can split UTF-8.
- `variables_json` always stores type text.
- The depth limit counts long `+` `/` and `chains`.
- `contains_text` on a list matches substrings.
- `-2^2 = 4` isn't documented.
- `1e5` passes number validation but is empty in PHP and text in JS.
- Unknown function names and unknown `[var]` references aren't rejected when publishing.
- The preview endpoint isn't tied to a form.

LOW Smaller loop issues V3-55 · Loops

LoopService.php:471-474 · FormField.php:2627 · _field_fill.php:30

- Wide column names can collide on `__`.
- Fixed codes aren't validated: `/`, `[ / ]`, duplicates and codes over 191 characters are all accepted.
- Input ids can clash.
- `loop_max` has no upper limit.
- The roster `hidden` list grows without limit in a TEXT column.
- Required errors don't say which repeat.

LOW **Smaller quota and randomisation issues** V3-56 · Quotas

QuotaService.php:69-71 · RandomisationService

- A quota's `parent_id` / `wave_id` isn't checked to belong to the same form.
- Test responses never get an arm, so arm routes can't be previewed.
- `storeScope` rewrites the stored orders without a lock.
- Pages have no show-N option, although it was specified.
- Dashboard counts include over-quota and screened-out responses in the overview totals (see V3-35).

LOW **Other low issues** V3-57 · General

helpers/Url.php:247 · ConsentService.php:954 · FormulaController.php

- A PHP 8 deprecation: `Url::toFolderDelete()` has an optional parameter before a required one.
- The consent audit event is always "given", even for a refusal.
- Consent timestamps mix UTC and local time.
- The formula preview is login-only, with no rate limit.
- The `routing_alignment` constant and the `routingAligned` JS branches remain as dead code.
- Hard-deleting a form (GOV-7) now also orphans audit, erasure, consent and quota rows (Plausible).

3. Status of the 126 earlier findings

Each finding was checked against the 1.30.0 code, not the changelog.

Logic and routing

FINDING	ORIGINALLY	IN 1.30.0	NOTE
LOG-1	Critical	REGRESSED	Browser ignores formula go-to/skip-page rules (V3-1).
LOG-2	Critical	FIXED	Action go-tos are applied on Next, with the same priority on both sides.
LOG-3	High	FIXED	The page limit is now the page count + 1.

FINDING	ORIGINALLY	IN 1.30.0	NOTE
LOG-4	High	FIXED WITH GAPS	Hidden answers are cleared for rules, but calculations still use raw values.
LOG-5	High	OPEN	Superseded by the formula engine, but PHP and JS still diverge (V3-10).
LOG-6	High	PARTIAL	Off by default, and the recorded order isn't the one shown (V3-22).
LOG-7	High	FIXED	The actor key is in the duplicate check.
LOG-8	Medium	OPEN	Go-to rules still fire from hidden fields.
LOG-9	Medium	PARTIAL	Backward go-tos are rejected. Unknown variables and functions, duplicate page keys and missing targets aren't.
LOG-10	Medium	PARTIAL	New operators exist. There's still one action per field and no "otherwise".
LOG-11	Medium	OPEN	Actions still have no conditions.
LOG-12	Low	PARTIAL	Dates work in PHP only. There's no server-side date or text-length validation.
LOG-13	Low	FIXED	The legacy columns and the dead branch are gone.

Data integrity and versioning

FINDING	ORIGINALLY	IN 1.30.0	NOTE
DAT-1	Critical	FIXED	Soft delete and RESTRICT. But see V3-36.
DAT-2	Critical	FIXED	Translation keys use the <code>c:</code> code prefix.
DAT-3	Critical	PARTIAL	Submit is atomic. Studio save, clone, import and restore aren't (V3-37).
DAT-4	High	FIXED WITH GAPS	No double binding, but the label+type fallback remains.
DAT-5	High	FIXED WITH GAPS	Only <code>logic_formula</code> references are rewritten (V3-52).

FINDING	ORIGINALLY	IN 1.30.0	NOTE
DAT-6	High	FIXED WITH GAPS	Piped labels aren't rewritten on clone.
DAT-7	High	FIXED WITH GAPS	The edition is signed, but a new response is validated against the current edition.
DAT-8	High	PARTIAL	An edition column is added. Draft-only columns and relabels are still shown.
DAT-9	Medium	OPEN	The code still defaults to the label.
DAT-10	Medium	PARTIAL	There's still a silent <code>_2</code> suffix and no unique index. Renames leave formulas dangling.
DAT-11	Medium	OPEN	No idempotency token or unique key.
DAT-12	Medium	OPEN	Drafts still delete hidden answers.
DAT-13	Medium	NOT APPLICABLE	Only relevant to live data.
DAT-14	Medium	OPEN	Resume codes are unchanged.
DAT-15	Medium	OPEN	Still N+1, and now worse with loops (V3-20).
DAT-16	Low	OPEN	—
DAT-17	Low	REGRESSED	The <code>id5</code> collision is now in the formula context too.
DAT-18	Low	OPEN	—
DAT-19	Low	OPEN	—

Governance

FINDING	ORIGINALLY	IN 1.30.0	NOTE
GOV-1	Critical	FIXED	Identity mode is enforced on submit.
GOV-2	Critical	REGRESSED	The completion and action email log re-links member to answer (V3-2).
GOV-3	High	FIXED WITH GAPS	An audit table exists. The reason is never posted, and there's no actor on anonymous forms (V3-44).

FINDING	ORIGINALLY	IN 1.30.0	NOTE
GOV-4	High	PARTIAL	Answers are kept and identity is cleared, but a lot is left behind (V3-30).
GOV-5	High	FIXED	Consent is opt-in eConsent; completing a form no longer stamps consent.
GOV-6	Medium	FIXED	Export is POST-only, permission-checked and logged.
GOV-7	Medium	OPEN	Still a hard delete.
GOV-8	Low	OPEN	The raw IP is still stored.

Security

FINDING	ORIGINALLY	IN 1.30.0	NOTE
SEC-1	High	FIXED WITH GAPS	Panels are checked, but not email template ids (V3-50).
SEC-2	High	FIXED WITH GAPS	See NEW-14 and <code>grantLegacy</code> .
SEC-3	High	FIXED	—
SEC-4	High	FIXED	—
SEC-5	High	FIXED WITH GAPS	The submit trigger is gone. It's still an email relay within the rate limit.
SEC-6	High	FIXED WITH GAPS	The token is atomic, but it's consumed too early (V3-32).
SEC-7	Medium	FIXED	Polls only, through the gate.
SEC-8	Medium	REGRESSED	The rate limit is per /24 and blocks shared NATs (V3-51).
SEC-9	Medium	FIXED	—
SEC-10	Medium	FIXED WITH GAPS	Negative numbers are prefixed. The codebook and allocation CSVs aren't neutralised (V3-41).
SEC-11	Medium	PARTIAL	Only export was narrowed.
SEC-12	Medium	FIXED WITH GAPS	<code>other_text</code> overwrites frozen answers.

FINDING	ORIGINALLY	IN 1.30.0	NOTE
SEC-13	Medium	PARTIAL	The quota lives in the session and trusts <code>field_id</code> . There's no file-type check.
SEC-14	Medium	FIXED WITH GAPS	The folder ACL can be bypassed through <code>folder_id</code> .
SEC-15	Low	OPEN	—
SEC-16	Low	OPEN	—
SEC-17	Low	OPEN	—
SEC-18	Low	OPEN	—
SEC-19	Low	OPEN	—
SEC-20	Low	OPEN	—

Response integrity

FINDING	ORIGINALLY	IN 1.30.0	NOTE
INT-1	High	FIXED	—
INT-2	High	FIXED WITH GAPS	Consistency and similarity ignore the route. Removed questions count as shown (V3-33).
INT-3	High	PARTIAL	Not chance-adjusted. Still the last 250 responses, run synchronously.
INT-4	Medium	FIXED WITH GAPS	A legacy value of 60 is read as seconds per question.
INT-5	Medium	FIXED	—
INT-6	Medium	OPEN	—
INT-7	Medium	OPEN	—
INT-8	Medium	REGRESSED	The counter still increments on failures, and it's per /24.
INT-9	Low	OPEN	—
INT-10	Low	FIXED	—

Scoring and analytics

FINDING	ORIGINALLY	IN 1.30.0	NOTE
SCO-1	High	PARTIAL	Balance is better for n=12, but items 9 and 10 are never shown for n=10, k=4, 5 sets. No versions.
SCO-2	High	FIXED WITH GAPS	Sets are rebuilt on save (V3-42).
SCO-3	High	PARTIAL	Best/Worst is fixed. MaxDiff produces no dashboard cells.
SCO-4	High	FIXED WITH GAPS	Column code 0 is dropped.
SCO-5	High	PARTIAL	Bands are per form. No consensus-out rule and no median/IQR.
SCO-6	High	FIXED WITH GAPS	Two paths still reset the weight to 1.
SCO-7	Medium	OPEN	—
SCO-8	Medium	OPEN	—
SCO-9	Medium	PARTIAL	The server now enforces it. It still needs a published summary.
SCO-10	Medium	OPEN	—
SCO-11	Medium	FIXED WITH GAPS	Levels come from codes. The first-5-radios fallback remains.
SCO-12	Medium	PARTIAL	—
SCO-13	Medium	OPEN	—
SCO-14	Medium	OPEN	—
SCO-15	Medium	OPEN	—
SCO-16	Medium	PARTIAL	Formula starters exist, with issues (V3-42).
SCO-17	Low	OPEN	—
SCO-18	Low	OPEN	—
SCO-19	Low	OPEN	—
SCO-20	Low	OPEN	—

FINDING	ORIGINALLY	IN 1.30.0	NOTE
SCO-21	Low	OPEN	—
SCO-22	Low	OPEN	—
SCO-23	Low	OPEN	—
SCO-24	Low	FIXED	Documented.
SCO-25	Low	PARTIAL	—

Accessibility

FINDING	ORIGINALLY	IN 1.30.0	NOTE
A11Y-1	High	PARTIAL	Grids are fixed. Best/Worst and MaxDiff aren't.
A11Y-2	High	PARTIAL	Several types still aren't grouped.
A11Y-3	High	FIXED WITH GAPS	The table and mobile copies aren't mirrored.
A11Y-4	Medium	PARTIAL	—
A11Y-5	Medium	FIXED WITH GAPS	—
A11Y-6	Medium	OPEN	—
A11Y-7	Medium	OPEN	—
A11Y-8	Medium	OPEN	—
A11Y-9	Low	OPEN	—

Version 2 defects

FINDING	ORIGINALLY	IN 1.30.0	NOTE
NEW-1	High	FIXED	—
NEW-2	High	FIXED	—
NEW-3	High	FIXED	—
NEW-4	High	FIXED	—

FINDING	ORIGINALLY	IN 1.30.0	NOTE
NEW-5	High	FIXED	—
NEW-6	High	FIXED	—
NEW-7	High	FIXED	—
NEW-8	High	FIXED	Superseded: the flag was removed.
NEW-9	High	FIXED	—
NEW-10	Medium	FIXED	—
NEW-11	Medium	FIXED WITH GAPS	Hard delete now breaks published editions (V3-36).
NEW-12	Medium	FIXED	—
NEW-13	Medium	FIXED	—
NEW-14	Medium	FIXED WITH GAPS	<code>grantLegacy</code> is too broad.
NEW-15	Medium	FIXED WITH GAPS	Polls record <code>captcha_shown=0</code> .
NEW-16	Medium	FIXED WITH GAPS	See A11Y-3.
NEW-17	Medium	FIXED WITH GAPS	Rejected only after saving (V3-37).
NEW-18	Low	FIXED	—
NEW-19	Low	FIXED WITH GAPS	The overview still shows about 1.
NEW-20	Low	FIXED	—
NEW-21	Medium	FIXED	The timing leak is fixed, but the direct link V3-2 replaces it.
NEW-22	Medium	PARTIAL	The tests are in the repo and gated, but there's no CI and no JS runner.

4. Quality of the release

AREA	ASSESSMENT
Tests	There are now 63 in-repo tests with a guarded runner (<code>THISCOVERY_FORMS_TEST_DB=1</code>), a real improvement. But: the 500 formula vectors are about 480 trivial operator × raw-string cases with no typed fields and almost no functions; <code>decimal.json</code> has 19 cases; the logic and routing vectors were deleted rather than converted; there are no loop or randomisation vector runners in PHP; and there's no CI configuration. Most of the Critical and High defects above would have been caught by per-operator parity vectors on typed fields, a routing parity suite, a randomisation distribution test, and a parallel-submit test.
Test leftovers in production code	Three <code>@example.test</code> guards (V3-29), a hard-coded development date (V3-9), and dead <code>routing_alignment</code> code. Add a CI grep for <code>example.test</code> and hard-coded dates outside <code>tests/</code> .
Architecture	The rule engine was replaced, as agreed, but a thin compatibility layer (<code>LogicEngine</code> , JS <code>logicMet / ruleMatches</code> shims) still carries old assumptions such as <code>rules.length</code> and a UTC <code>today</code> . The browser evaluator is a separate hand-written port, with no shared generated function table.
Migrations	Generally careful: guarded, idempotent, and rollbacks refuse to destroy data. Watch the index-swap window and the eConsent backfill (V3-53).
Docs	Good user docs for every feature (<code>docs/user/*.md</code>), and a detailed, honest changelog.

5. What's done well

- Almost every version 2 defect is fixed, with a changelog that states limitations plainly.
- The formula engine has no `eval` or dynamic dispatch. Parser depth and node limits hold. Decimal rounding, negative rounding, `0.1+0.2` , division by zero, empty propagation, leap years, month-end clamping and DST all match between PHP and JS.
- The loops storage change (`instance_key` in the unique key) is sound. Roster keys are generated on the server and validated, and injected instance keys are ignored.
- The randomisation design is right: a 128-bit server seed, stored orders, no shuffling in the browser, and go-to targets outside a block are refused.

- Quota counters are locked with `FOR UPDATE` in id order inside the submit transaction, and parent quotas are checked first.
- eConsent versions are frozen, withdrawal tokens are 128-bit, hashed and single-use, and viewing consent is a separate permission.
- Export is POST-only, permission-checked and logged. There are container checks on panels, folders and templates, and upload and rate limits.
- Rollback guards refuse to destroy data.

6. Recommended 1.30.1 stabilisation plan

P0

blockers

- V3-1: browser go-to and skip-page rules use `when`. Bring back routing parity vectors.
- V3-2, V3-8, V3-26: no member↔answer link on anonymous forms (email log, weight copy, consent record). No free text or names on public dashboards.
- V3-3, V3-13, V3-14: server ownership. Clear posted calculated values and evaluate in dependency order; persist variables and URL parameters at start; the browser must never lose calculated values.
- V3-4: digit caps in Decimal and on number questions; lock down the preview endpoint.
- V3-5, V3-6: replace the random generator with HMAC-SHA256 Fisher–Yates and rejection sampling; lock-then-read allocation.
- V3-7: idempotent quota accepts, and no re-check on edits.
- V3-9, V3-10, V3-11, V3-12: generate the browser evaluator's function table from the PHP one (or port every function), send the frozen `formula_today`, fix `"0"`, `%`, `sqrt`, and `and / or` arity.
- V3-29, V3-31, V3-36: remove the test guards, validate redirects, never hard-delete a question that's in an edition.

P1

before any study uses the feature

- Loops: V3-15 to V3-20, V3-45, V3-46.
- Quotas and randomisation: V3-21 to V3-25, V3-47, V3-48.
- eConsent and governance: V3-27, V3-28, V3-30, V3-43, V3-44.
- Integrity: V3-32 to V3-35, V3-51.
- Studio: V3-37 (transactional, validate-before-write save).

Test gates

must exist before
release

- PHP/JS parity vectors for every operator and function, on typed contexts (choice, number, rating, date, grid, loop), including edge cases and limits: at least 1,500 generated cases.
- A routing parity suite (converted `routing.json`) that runs in PHP and Node, with formula go-to and skip-page cases.
- Randomisation statistics: position uniformity, independence across scopes, block balance, run over 100,000 seeds.
- Concurrency: 50 parallel starts (allocation) and 100 parallel submits (quotas), plus edits of completed responses.
- Privacy: a test that no table joins a member to an answer on fully anonymous forms, and that public pages contain no free text.
- CI that runs the PHP and Node suites, and a grep for test-only guards.

Then

1.31

- The remaining Medium and Low items. The still-open original findings: DAT-11/12/14/15, SEC-11/15 to 20, INT-6/7/9, SCO-7/8/10/13 to 23, A11Y-6 to 9, GOV-7/8.
- Webhooks (deferred).

Method. Read-only review of `thiscovery-forms-5` (v1.30.0) against `thiscovery-forms-4` (v1.28.3) and `thiscovery-forms-3` (v1.28.2). Six parallel reviews covered the status of the 126 earlier findings (two reviewers), the formula engine, loops, quotas with randomisation, and eConsent with the security of the new endpoints. Their results were merged and de-duplicated. The formula engine and randomisation were exercised with standalone PHP and Node harnesses (about 105 adversarial expressions; 300,000 random seeds). The most serious claims were re-checked against the source and tagged Verified. Nothing was run against a HumHub instance. Line numbers refer to v1.30.0.